Penetration Test Interno
Reporte de vulnerabilidades
(Versión:1.0)

Matias Nahuel Heredia

September 2024



Índice

1 Versionado **3**

2 Contrato de Confidencialidad **3**

3 Contactos Involucrados **3**

4 Resumen Ejecutivo **3**
4.1 Enfoque . . . 3
4.2 Alcance . . . 4
4.3 Activos en Alcance . . . 4
4.4 Resumen de Evaluación y Recomendaciones . . . 4

5 Resumen de Evaluación de Prueba de Penetración de Red **5**
5.1 Escala de calificación de riesgos de seguridad de la información . . . 6
5.2 Resumen de Hallazgos . . . 6
5.3 Tendencia . . . 7

6 Recorrido de Compromiso de Red Interna **8**
6.1 Recorrido Detallado . . . 9

7 Resumen de Remediación **9**
7.1 Corto Plazo . . . 9
7.2 Mediano Plazo . . . 9
7.3 Largo Plazo . . . 10

8 Detalles Técnicos de los Hallazgos **11**
8.1 Detalles . . . 11

9 Apéndices **13**
9.1 Apéndice A – Gravedad de los Hallazgos . . . 13
9.2 Apéndice B – Hosts Explotados . . . 13
9.3 Apéndice C – Usuarios Comprometidos . . . 13
9.4 Apéndice D – Cambios/Limpieza de Hosts . . . 13
9.5 Apéndice E – Revisión de Contraseñas del Dominio I.N.E .LOCAL . . . 13

10 Agradecimientos y Cierre Formal **14**

1 Versionado

History Document Versions	
Version	**Description**
1.0	First Pentesting

2 Contrato de Confidencialidad

El contenido de este documento ha sido desarrollado por Matias Nahuel Heredia . El autor considera que el contenido de este documento es información confidencial y propietaria de la empresa. Esta información debe ser utilizada únicamente para su propósito previsto.
Este documento no puede ser divulgado a otro proveedor, socio comercial o contratista sin el consentimiento previo por escrito de Matias Nahuel Heredia . Además, ninguna parte de este documento puede ser comunicada, reproducida, copiada o distribuida sin el consentimiento previo de Matias Nahuel Heredia . El contenido de este documento no constituye asesoramiento legal. Los servicios ofrecidos por Matias Nahuel Heredia relacionados con el cumplimiento, litigios u otros intereses legales no están destinados a ser tomados como asesoramiento jurídico y no deben interpretarse como tal. La evaluación detallada en este documento se refiere a una empresa ficticia con fines de examen, y las vulnerabilidades aquí mencionadas de ninguna manera afectan la infraestructura interna o externa de I.N.E .

3 Contactos Involucrados

Contactos de Inlanefreight		
Matías Nahuel Heredia	**Analista de Sistemas de Información**	**matiasnahuelheredia@gmail.com**

Contacto del Evaluador		
-	**-**	**-**

4 Resumen Ejecutivo

I.N.E Ltd. (“I.N.E ” en adelante) contrató a Matias Nahuel Heredia para realizar una Prueba de Penetración de Red en la red interna de I.N.E con el objetivo de identificar debilidades de seguridad, determinar el impacto para I.N.E , documentar todos los hallazgos de manera clara y repetible, y proporcionar recomendaciones de remediación.

4.1 Enfoque

Matias Nahuel Heredia realizó pruebas bajo un enfoque de “Black Box ” desde May 12, 2022 hasta May 31, 2022 , sin credenciales ni conocimiento previo del entorno interno de I.N.E , con el objetivo de identificar debilidades desconocidas. Las pruebas se realizaron desde un punto de vista no invasivo con el objetivo de descubrir la mayor cantidad posible de configuraciones erróneas y vulnerabilidades. Las pruebas se llevaron a cabo de forma remota a través de un host que fue aprovisionado específicamente para esta evaluación. Cada debilidad identificada fue documentada e investigada manualmente para determinar las posibilidades de explotación y el potencial de escalamiento.

Matias Nahuel Heredia buscó demostrar el impacto total de cada vulnerabilidad, incluyendo el compromiso del dominio interno. Si Matias Nahuel Heredia lograba obtener un punto de apoyo en la red interna, I.N.E permitió realizar pruebas adicionales, incluyendo movimiento lateral y escalamiento de privilegios horizontales/verticales, para demostrar el impacto de un compromiso de la red interna.

4.2 Alcance

El alcance de esta evaluación fue un rango de red interna en el dominio I.N.E .

4.3 Activos en Alcance

Activos Dentro del Alcance	
Host/URL/Dirección IP	**Descripción**
192.168.195.0/24	**Red interna de Inlanefreight**

4.4 Resumen de Evaluación y Recomendaciones

Durante la prueba de penetración interna contra I.N.E , Matias Nahuel Heredia identificó 15hallazgos que amenazan la confidencialidad, integridad y disponibilidad de los sistemas de información de I.N.E . Los hallazgos fueron clasificados por nivel de gravedad, con 1 de los hallazgos asignados con una calificación de riesgo crítico, 2 de alto riesgo, 3 de riesgo medio, 4 de bajo riesgo y 5 de riesgo informativo. También hubo un (1) hallazgo informativo relacionado con la mejora de las capacidades de monitoreo de seguridad dentro de la red interna. El evaluador encontró que la gestión de parches y vulnerabilidades de I.N.E estaba bien mantenida. Ninguno de los hallazgos en este informe estuvo relacionado con la falta de parches de sistema operativo o de terceros sobre vulnerabilidades conocidas en servicios y aplicaciones que podrían resultar en acceso no autorizado y compromiso del sistema. Cada defecto descubierto durante las pruebas estuvo relacionado con una mala configuración o falta de endurecimiento, siendo la mayoría de ellos problemas de autenticación débil y autorización débil. Un hallazgo involucró un protocolo de comunicación de red que puede ser “suplantado” para obtener contraseñas de usuarios internos que pueden ser utilizadas para obtener acceso no autorizado si un atacante puede acceder a la red sin credenciales. En la mayoría de los entornos corporativos, este protocolo es innecesario y puede deshabilitarse. Está habilitado por defecto principalmente para pequeñas y medianas empresas que no tienen los recursos para un servidor dedicado de resolución de nombres (el “directorio telefónico” de su red). Durante la evaluación, se observó la presencia de estos recursos en la red, por lo que I.N.E debería comenzar a formular un plan de pruebas para deshabilitar el servicio peligroso. El siguiente problema fue una configuración débil relacionada con cuentas de servicio que permite a cualquier usuario autenticado robar un componente del proceso de autenticación que a menudo puede adivinarse fuera de línea (mediante “cracking” de contraseñas) para revelar la contraseña del usuario en forma legible. Este tipo de cuentas de servicio suelen tener más privilegios que un usuario estándar, por lo que obtener una de sus contraseñas en texto claro podría resultar en movimiento lateral o escalada de privilegios y eventualmente en un compromiso total de la red interna. El evaluador también notó que la misma contraseña se usaba para el acceso de administrador a todos los servidores dentro de la red interna. Esto significa que si un servidor es comprometido, un atacante puede reutilizar esta contraseña para acceder a cualquier servidor que la comparta para acceso administrativo. Afortunadamente, ambos problemas pueden corregirse sin la necesidad de herramientas de terceros. Active Directory de Microsoft contiene configuraciones que se pueden utilizar para minimizar el riesgo de que estos recursos sean explotados en beneficio de usuarios maliciosos. También se encontró un servidor web ejecutando una aplicación web que usaba credenciales débiles y fácilmente adivinables para acceder a una consola administrativa que puede ser aprovechada para obtener acceso no autorizado al servidor subyacente. Esto podría ser explotado por un atacante en la red interna sin necesidad de una cuenta de usuario válida. Este ataque está muy bien documentado, por lo que es un objetivo muy probable que puede ser particularmente dañino, incluso en manos de un atacante no capacitado. Idealmente, el acceso externo directo a este servicio debería deshabilitarse, pero si no puede ser, debe reconfigurarse con credenciales excepcionalmente fuertes que se roten con frecuencia. I.N.E también debería considerar maximizar los datos de registro recopilados desde este dispositivo para garantizar que los ataques contra él puedan ser detectados y triados rápidamente. El evaluador también encontró carpetas compartidas con permisos excesivos, lo que significa que todos los usuarios en la red interna pueden acceder a una cantidad considerable de datos. Si bien compartir archivos internamente entre departamentos y usuarios es importante para las operaciones diarias del negocio, permisos abiertos en las comparticiones de archivos pueden resultar en la divulgación no intencionada de información confidencial. Incluso si una compartición de archivos no contiene información sensible hoy en día, alguien podría poner allí esos datos sin darse cuenta pensando que están protegidos cuando no lo están. Esta configuración debe cambiarse para garantizar que los usuarios solo puedan acceder a lo necesario para realizar sus tareas diarias. Finalmente, el evaluador notó que las actividades de prueba parecían pasar desapercibidas, lo que podría representar una oportunidad para mejorar la visibilidad en la red interna e indica que un atacante real podría permanecer indetectado si se logra acceso interno. I.N.E debería crear un plan de remediación basado en la sección Resumen

de Remediación de este informe, abordando todos los hallazgos críticos lo antes posible de acuerdo con las necesidades del negocio. I.N.E también debería considerar realizar evaluaciones periódicas de vulnerabilidades si aún no se están llevando a cabo. Una vez que los problemas identificados en este informe hayan sido abordados, una evaluación de seguridad más colaborativa y profunda de Active Directory podría ayudar a identificar oportunidades adicionales para fortalecer el entorno de Active Directory, dificultando el movimiento de los atacantes por la red y aumentando la probabilidad de que I.N.E pueda detectar y responder a actividad sospechosa.

5 Resumen de Evaluación de Prueba de Penetración de Red

Matias Nahuel Heredia comenzó todas las actividades de prueba desde la perspectiva de un usuario no autenticado en la red interna. I.N.E proporcionó al evaluador los rangos de red, pero no proporcionó información adicional, como el sistema operativo o información de configuración.

5.1 Escala de calificación de riesgos de seguridad de la información

Escala de Clasificación de Riesgos de Seguridad de la Información		
Severidad	**Puntuación Base**	**Descripción**
Crítica	**9.0 - 10.0**	**Descripción:** Impacta gravemente la confidencialidad, integridad o disponibilidad de la información, los sistemas o la infraestructura. Permite la explotación de vulnerabilidades críticas que ponen en peligro inmediato la seguridad de la organización.
Alta	**7.0 - 8.9**	**Descripción:** Riesgo alto que afecta la seguridad, aunque su explotación no ocurre de forma inmediata. Requiere atención prioritaria para mitigar el riesgo, ya que puede comprometer a la organización si no se aborda adecuadamente.
Media	**4.0 - 6.9**	**Descripción:** Riesgo moderado con impacto potencial en la seguridad. No representa una amenaza inmediata, pero debe ser tratado para evitar que se convierta en un problema más grave.
Baja	**0.1 - 3.9**	**Descripción:** Riesgo menor con impacto limitado en la seguridad de la información. Requiere monitoreo, pero no necesita acción urgente.
Informativa	**0.0**	**Descripción:** No representa un riesgo significativo, pero proporciona información útil sobre áreas de mejora potencial o detalles adicionales sobre la infraestructura o configuración.

5.2 Resumen de Hallazgos

Durante el curso de la evaluación, Matias Nahuel Heredia descubrió un total de 15 hallazgos que representan un riesgo material para los sistemas de información de I.N.E . Matias Nahuel Heredia también identificó un hallazgo informativo que, si se aborda, podría fortalecer aún más la postura general de seguridad de I.N.E . Los hallazgos informativos son observaciones sobre áreas de mejora para la organización y no representan vulnerabilidades de seguridad por sí solas. La siguiente tabla proporciona un resumen de los hallazgos clasificados por nivel de severidad.

Severidad de los Hallazgos					
Crítico	**Alto**	**Medio**	**Bajo**	**Informativo**	**Total**
1	**2**	**3**	**4**	**5**	**15**

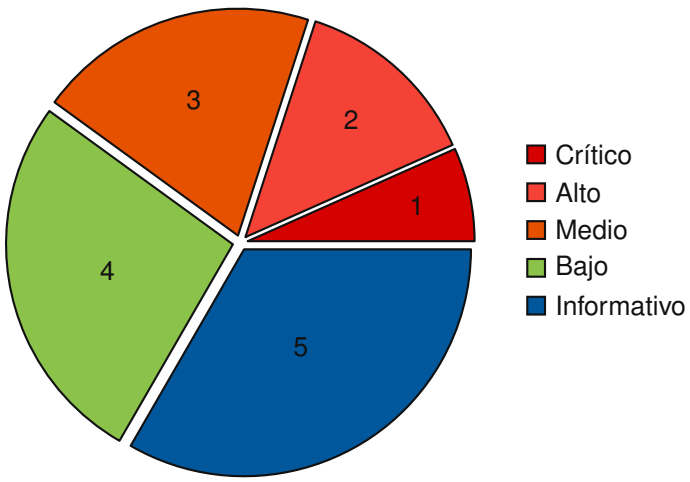


Figura 1: Distribución de Vulnerabilidades

A continuación se muestra un resumen de alto nivel de cada hallazgo identificado durante la evaluación. Estos hallazgos se abordan en detalle en la sección de Hallazgos Técnicos del presente informe.

#Hallazgo	Estado	Nivel de Severidad	Nombre del Hallazgo
2	Nuevo	Alto	Suplantación de Respuesta LLMNR/NBT-NS
1	Nuevo	Bajo	Algo

5.3 Tendencia

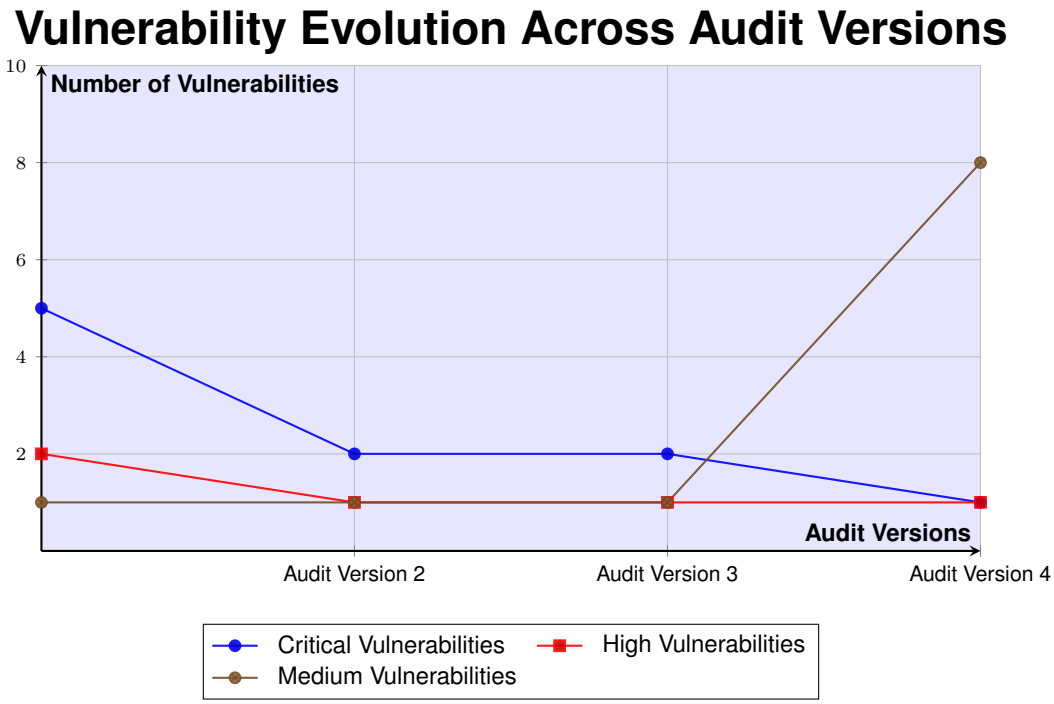


Figura 2: Vulnerability Evolution Across Audit Versions (With Trend Lines)

Evolución de Vulnerabilidades – Gráfico de Telaraña Hexagonal



Figura 3: Comparación de vulnerabilidades mediante gráfico de telaraña hexagonal

6 Recorrido de Compromiso de Red Interna

Durante el transcurso de la evaluación, Matias Nahuel Heredia pudo obtener un acceso inicial y comprometer la red interna, lo que llevó a obtener control administrativo completo sobre el dominio Active Directory I.N.E .LOCAL. Los pasos a continuación demuestran el camino tomado desde el acceso inicial hasta el compromiso, y no incluyen todas las vulnerabilidades y configuraciones incorrectas descubiertas durante el proceso de pruebas. Cualquier problema no utilizado como parte del camino hacia el compromiso se enumera como problemas separados e independientes en la sección de Detalles de los Hallazgos Técnicos, clasificados por nivel de severidad. El objetivo de esta cadena de ataque es demostrar a I.N.E el impacto de cada vulnerabilidad mostrada en este informe y cómo se conectan entre

sí para demostrar el riesgo general para el entorno del cliente y ayudar a priorizar los esfuerzos de remediación (es decir, corregir dos fallos rápidamente podría interrumpir la cadena de ataque mientras la empresa trabaja para remediar todos los problemas reportados). Aunque otros hallazgos mostrados en este informe podrían ser aprovechados para obtener un nivel de acceso similar, esta cadena de ataque muestra el camino inicial de menor resistencia tomado por el evaluador para lograr el compromiso del dominio.

6.1 Recorrido Detallado

——————————— TODO tutorial ———————————

Matias Nahuel Heredia realizó las siguientes acciones para comprometer completamente el dominio I.N.E .LOCAL. 1. El evaluador utilizó la herramienta Responder para obtener un hash de contraseña NTLMv2 de un usuario del dominio, bsmith. 2. Este hash de contraseña fue descifrado exitosamente fuera de línea usando la herramienta Hashcat, revelando la contraseña en texto claro del usuario, lo que otorgó un punto de acceso al dominio I.N.E .LOCAL, pero sin más privilegios que los de un usuario estándar del dominio. 3. Luego, el evaluador ejecutó BloodHound.py, una versión en Python de la popular herramienta de recolección SharpHound, para enumerar el dominio y crear representaciones visuales de las rutas de ataque. Tras una revisión, el evaluador encontró que existían múltiples usuarios privilegiados en el dominio configurados con Service Principal Names (SPNs), los cuales pueden ser aprovechados para realizar un ataque de Kerberoasting y recuperar tickets TGS de Kerberos para las cuentas. Estos tickets pueden ser descifrados fuera de línea usando Hashcat si se ha configurado una contraseña débil. Desde este punto, el evaluador utilizó la herramienta GetUserSPNs.py para realizar un ataque Kerberoasting dirigido contra la cuenta mssqlsvc, encontrando que dicha cuenta tenía derechos de administrador local sobre el host SQL01.I.N.E .LOCAL, lo que resultaba un objetivo interesante en el dominio. 4. El evaluador logró descifrar exitosamente la contraseña de esta cuenta fuera de línea, revelando su valor en texto claro. 5. El evaluador pudo autenticarse en el host SQL01.I.N.E .LOCAL y recuperar una contraseña en texto claro del registro del host al descifrar secretos LSA para una cuenta (srvadmin) que estaba configurada para inicio de sesión automático. 6. Esta cuenta srvadmin tenía derechos de administrador local sobre todos los servidores (excepto los Controladores de Dominio) en el dominio, por lo que el evaluador pudo iniciar sesión en el host MS01.I.N.E .LOCAL y recuperar un ticket TGT de Kerberos para un usuario conectado, pramirez, quien formaba parte del grupo de Administradores de Servidores de Nivel I, otorgándole al evaluador derechos de DCSync sobre el objeto del dominio. Este ataque puede ser utilizado para recuperar el hash de contraseña NTLM de cualquier usuario en el dominio, resultando en el compromiso del dominio y persistencia mediante un Golden Ticket. 7. El evaluador utilizó la herramienta Rubeus para extraer el ticket TGT de Kerberos del usuario pramirez y realizar un ataque de Pass-the-Ticket para autenticarse como este usuario. 8. Finalmente, el evaluador logró realizar un ataque DCSync después de autenticarse exitosamente con esta cuenta de usuario utilizando la herramienta Mimikatz, lo que resultó en el compromiso total del dominio.

7 Resumen de Remediación

Como resultado de esta evaluación, existen varias oportunidades para que I.N.E fortalezca la seguridad de su red interna. Los esfuerzos de remediación se priorizan a continuación, comenzando con aquellos que probablemente tomarán menos tiempo y esfuerzo para completar. I.N.E debe asegurarse de que todos los pasos de remediación y controles mitigantes sean cuidadosamente planificados y probados para prevenir cualquier interrupción de servicio o pérdida de datos.

7.1 Corto Plazo

- [Finding 2] – Establecer contraseñas fuertes (de 24 caracteres o más) en todas las cuentas SPN
- [Finding 5] – Cambiar las credenciales de administrador predeterminadas para el Tomcat Manager
- [Finding 7] – Deshabilitar el listado de directorios en el servidor web afectado
- Forzar un cambio de contraseña para todos los usuarios debido al compromiso del dominio

7.2 Mediano Plazo

- .[Hallazgo 1] – Deshabilitar LLMNR y NBT-NS siempre que sea posible
- .[Hallazgo 2] – Transicionar de SPNs a Cuentas de Servicio Gestionadas por Grupos (gMSA) siempre que sea posible

7.3 Largo Plazo

- Realizar evaluaciones continuas de vulnerabilidades en la red interna y auditorías de contraseñas de dominio
- Realizar evaluaciones periódicas de seguridad de Active Directory
- Educar a los administradores de sistemas, redes y desarrolladores sobre las mejores prácticas de endurecimiento de seguridad
- Mejorar la segmentación de la red para aislar los hosts críticos y limitar los efectos de un compromiso interno

8 Detalles Técnicos de los Hallazgos

8.1 Detalles

CWE	**CWE-522**
Puntuación CVSS 3.1	**9.5**
Impacto	**9.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)**
Descripción (Incl. Causa Raíz)	**Respondiendo al tráfico de red LLMNR/NBT-NS**
Impacto de Seguridad	**Los adversarios pueden suplantar una autoridad**
Dominio Afectado	**INLANEFREIGHT.LOCAL**
Remediación	**Deshabilitar LLMNR y NetBIOS en la configuración de seguridad del equipo local o mediante políticas de grupo si no son necesarios en el entorno. Usar software de seguridad basado en el host para bloquear el tráfico LLMNR/NetBIOS. Habilitar la firma SMB puede detener los ataques de retransmisión NTLMv2. Los sistemas de detección y prevención de intrusiones que identifiquen patrones de tráfico indicativos de actividad MiTM pueden mitigar la actividad a nivel de red. La segmentación de red puede usarse para aislar componentes de infraestructura que no requieran acceso amplio a la red. Esto puede mitigar, o al menos aliviar, el alcance de la actividad MiTM.**
Referencias Externas	https://attack.mitre.org/techniques/T1557/001/

CWE	**CWE-522**
Puntuación CVSS 3.1	**9.5**
Impacto	**9.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)**
Descripción (Incl. Causa Raíz)	**Respondiendo al tráfico de red LLMNR/NBT-NS**
Impacto de Seguridad	**Los adversarios pueden suplantar una autoridad**
Dominio Afectado	**INLANEFREIGHT.LOCAL**
Remediación	**(Texto igual que el anterior)**
Referencias Externas	https://attack.mitre.org/techniques/T1557/001/

Evidencia de los Hallazgos:
Ejecutando la herramienta Responder para intentar obtener los hashes de contraseñas de cuentas de usuario.

```
$ sudo responder -I eth0 -wrfv

           __
  .----.-----.-----.-----.-----.-----.--|  |.-----.----.
  |   _|  -__|__ --|  _  |  _  |     |  _  ||  -__|   _|
  |__| |_____|_____|   __|_____|__|__|_____||_____|__|
                   |__|

           NBT-NS, LLMNR & MDNS Responder 3.0.6.0

 <SNIP>

[+] Generic Options:
    Responder NIC              [eth0]
    Responder IP               [192.168.195.168]
    Challenge set              [random]
    Don't Respond To Names     ['ISATAP']

[+] Current Session Variables:
    Responder Machine Name     [WIN-TWWXTGD94CV]
    Responder Domain Name      [3BKZ.LOCAL]
    Responder DCE-RPC Port     [47032]

[+] Listening for events...

<SNIP>

[SMB] NTLMv2-SSP Client   : 192.168.195.205
[SMB] NTLMv2-SSP Username : INLANEFREIGHT\bsmith
[SMB] NTLMv2-SSP Hash     :
bsmith::INLANEFREIGHT:7ecXXXXXX98ebc:73D1B2XXXXXXXXXXX45085A651:0101000000000000000B588D9F766D801191BB2236A5FA
AA5000000000200080033004200 4B005A0001001E00570049004E002D0054005700570058005400470044003900340043005600040034
00570049004E002D0054005700570058005400470044003900340043005600 2E00330042004B005A002E004CXXXXXXXXXXXXXXXXXXXXXX
XXXXXXXXXXX2E004C004F00430041004C000700080000B588D9F766D8010600040002000000080030003000000000000000001000000000
2000002CAE5BF3BB1FD2F846A280AEF43A8809C15207BFCB4DF5A580BA1B6FCAF6BBCE0A0010000000000000000000000000000000000000
009002800630069006600730 02F003100390032002E003100360038002E003100390035002E00310036003800000000000000000000000
0000

<SNIP>
```

Figura 4: Introducir leyenda aquí

Descifrado exitoso de un hash de contraseña con Hashcat para revelar el valor en texto claro.

9 Apéndices

9.1 Apéndice A – Gravedad de los Hallazgos

Cada hallazgo ha sido clasificado con un nivel de gravedad: crítico, alto, medio o bajo. La clasificación se basa en una evaluación de la prioridad con la que cada hallazgo debe ser considerado y el impacto potencial que puede tener en la confidencialidad, integridad y disponibilidad de los datos de I.N.E .

9.2 Apéndice B – Hosts Explotados

9.3 Apéndice C – Usuarios Comprometidos

9.4 Apéndice D – Cambios/Limpieza de Hosts

9.5 Apéndice E – Revisión de Contraseñas del Dominio I.N.E .LOCAL

10 Agradecimientos y Cierre Formal

Queremos expresar nuestro más sincero agradecimiento a I.N.E por su cooperación y apoyo durante el compromiso de prueba de penetración. Su disposición para proporcionar acceso a los sistemas y colaborar con el equipo de pruebas fue crucial para el éxito de esta evaluación. También agradecemos al equipo de TI y a los administradores de sistemas por su colaboración y por facilitar los recursos necesarios para llevar a cabo eficazmente la evaluación.

Este informe presenta los hallazgos de la prueba de penetración, junto con recomendaciones detalladas para mejorar la postura de seguridad. Es importante señalar que la seguridad es un proceso continuo, y recomendamos revisar e implementar las medidas correctivas según las prioridades del negocio.

Agradecemos la oportunidad de haber trabajado en este proyecto y estamos disponibles para cualquier aclaración adicional o para asistir con la implementación de las recomendaciones.

Atentamente,
Matias Nahuel Heredia
Analista de Sistemas de Información